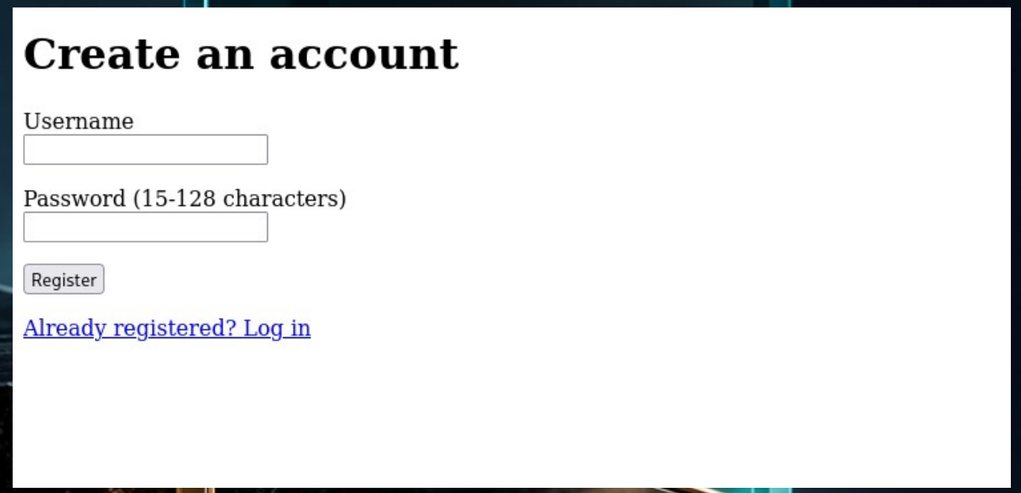
מעבדה אישית באבטחת מידע

PT WEB LAB

פיתוח, הגנה ובדיקות חדירה
תיעוד ממעבדה אישית



האפליקציה שבניתי במעבדה

איתי בכור
אוקטובר 2026

אפליקציית Web במעבדה עצמאית



פיתחתי מערכת הרשמה וכניסה ב־Python ו־Flask על Kali, עם SQLite. המטרה: ללמוד פיתוח מאובטח ולבדוק בפועל את מנגנוני ההגנה.

סיסמאות נשמרות בגיבוב

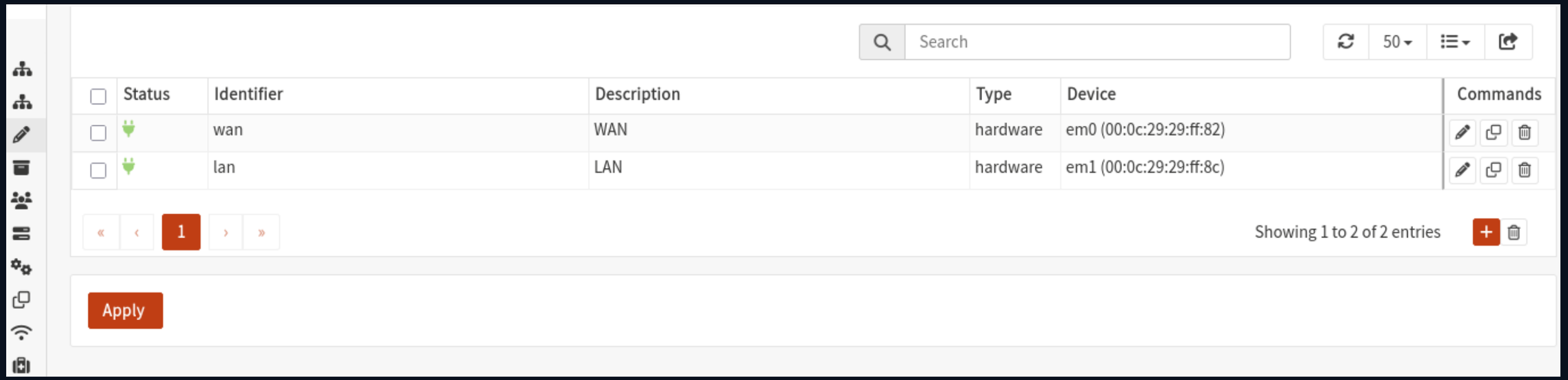
```
┌──(kali㉿kali)-[~/pt-web-lab]
└─$ cd ~/pt-web-lab
sqlite3 -header -column users.db "SELECT id, username, substr(password_hash, 1, 6) AS hash_type FROM users
;"
id  username   hash_type
--  ---------  ---------
1   itay_test  scrypt

┌──(kali㉿kali)-[~/pt-web-lab]
└─$ cd ~/pt-web-lab
sqlite3 -header -column users.db "SELECT id, username, substr(password_hash, 1, 6) AS hash_type FROM users
;"
id  username   hash_type
--  ---------  ---------
1   itay_test  scrypt
2   itay2003   scrypt

┌──(kali㉿kali)-[~/pt-web-lab]
└─$
```

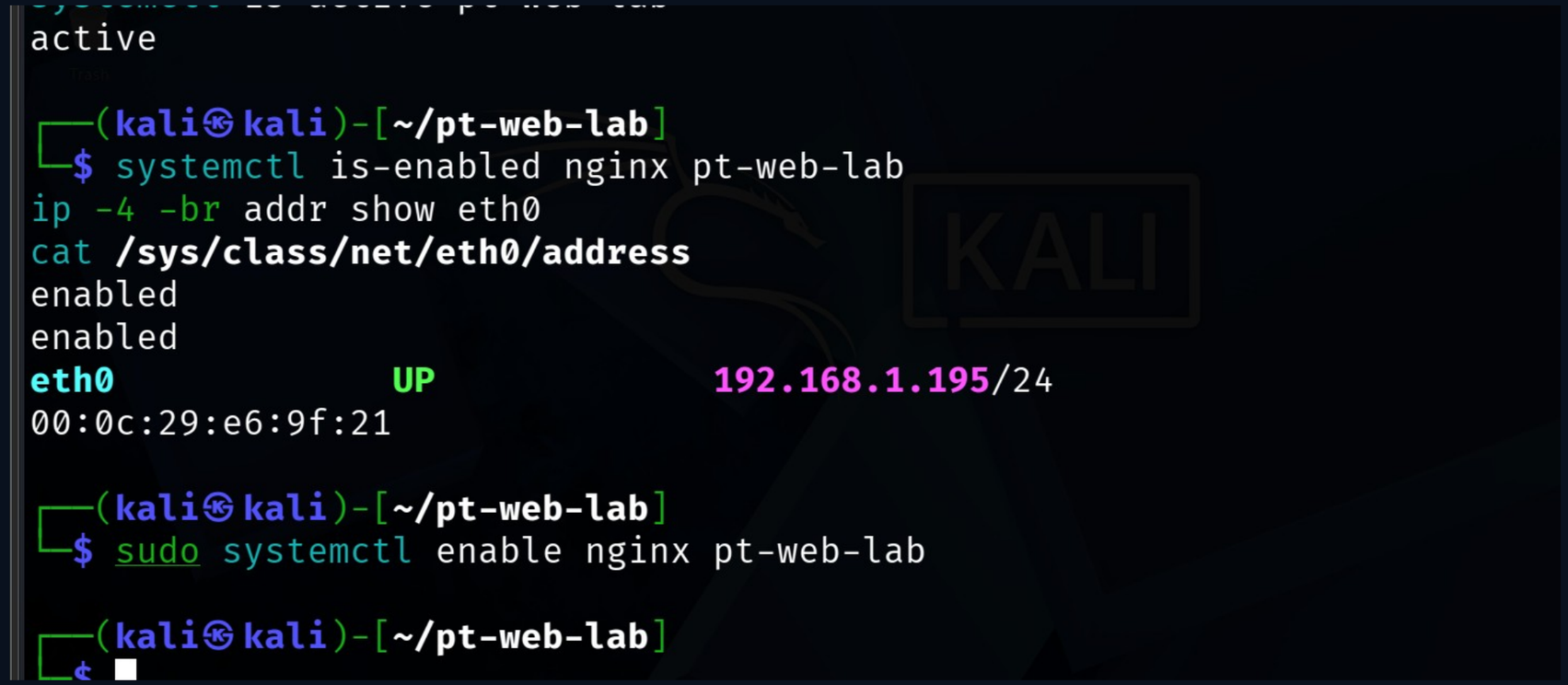
בדקתי במסד הנתונים שהיישום משתמש ב־scrypt. הסיסמה עצמה אינה נשמרת כטקסט גלוי.

הפרדה בין הרשתות



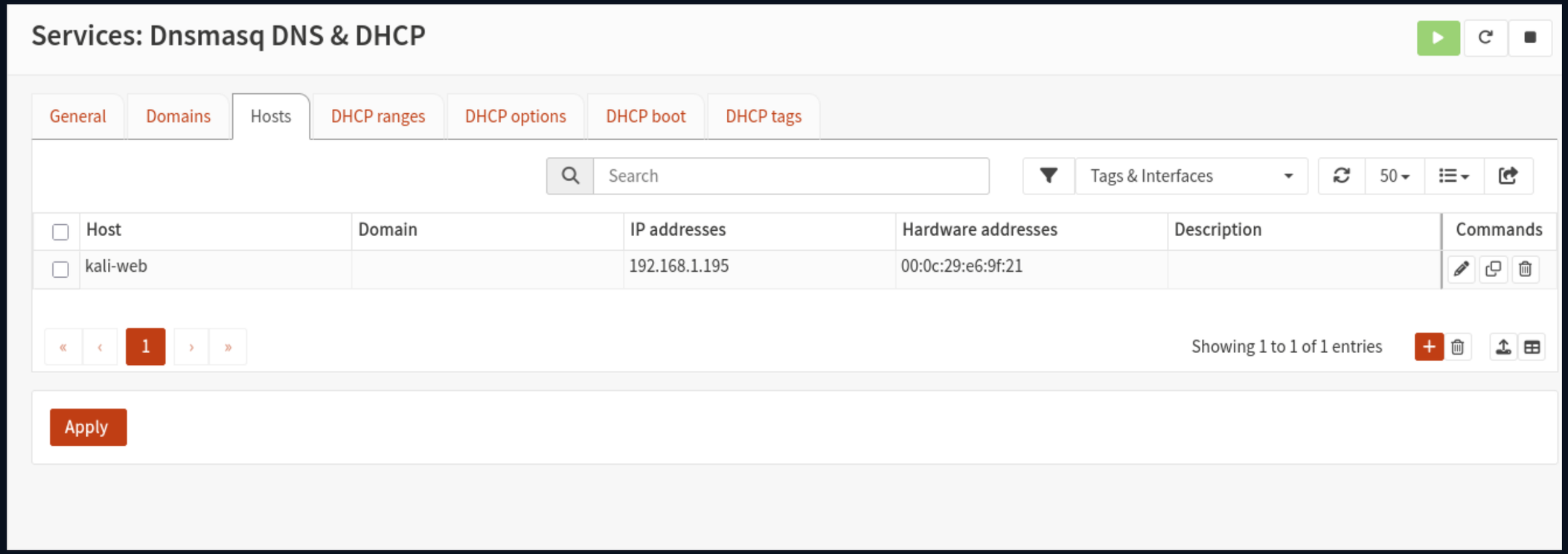
הקמתי OPNsense עם ממשקי WAN ו־LAN. מחשב הבדיקה פונה לכתובת ה־WAN, והאתר פועל ברשת הפנימית.

האתר עולה כשירות



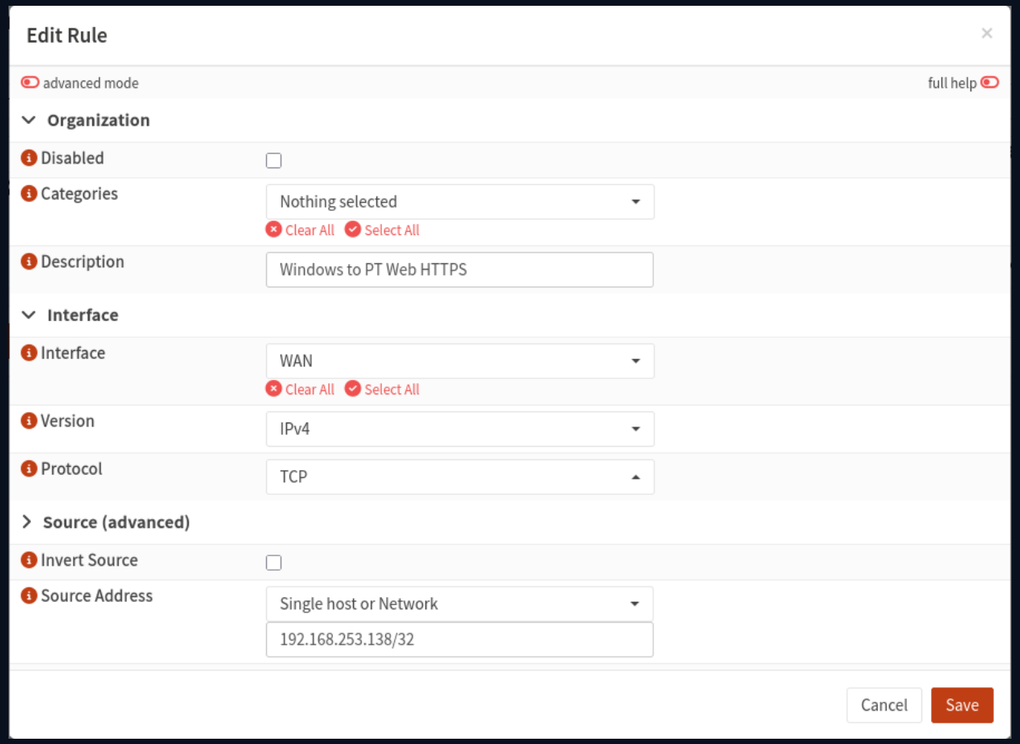
הגדרתי הפעלה אוטומטית ליישום ול־Nginx. הבדיקה מציגה שירותים פעילים וכתובת שרת קבועה במעבדה.

כתובת קבועה לשרת



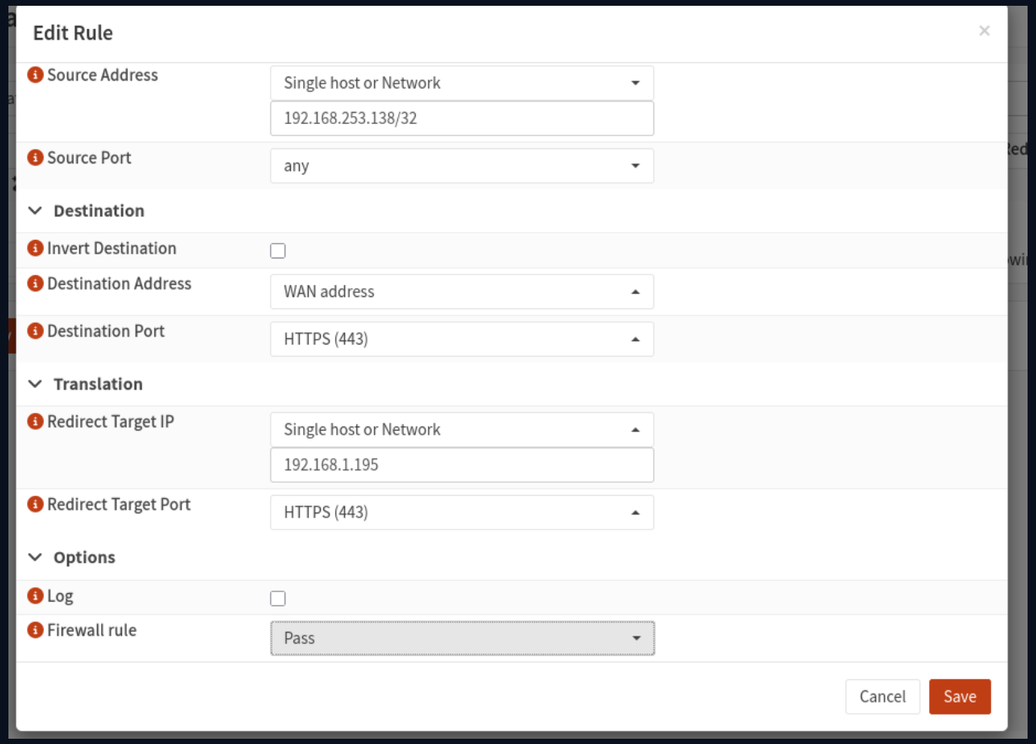
שמרתי חכירת DHCP לפי כתובת ה־MAC של Kali. כך חוק ההפניה ממשיך להפנות אל אותו שרת.

גישה ממקור מורשה בלבד



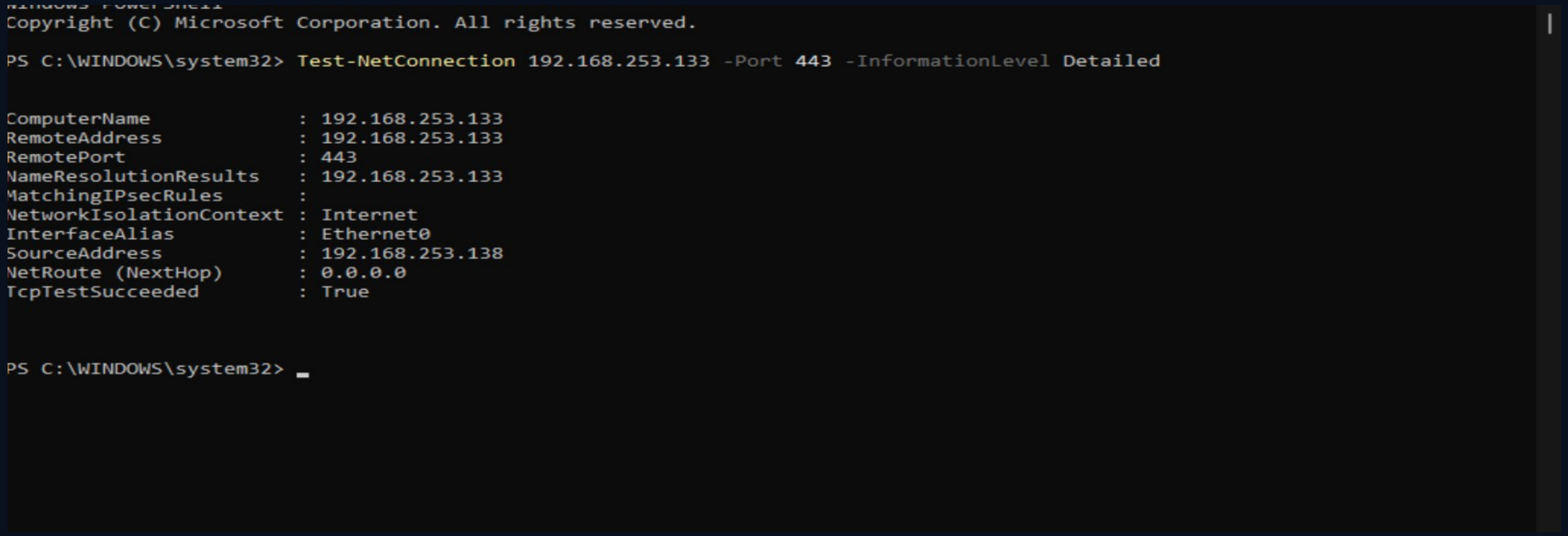
הגבלתי את מקור חוק ה־HTTPS לכתובת מחשב הבדיקה: 192.168.253.138/32. ההרשאה אינה ניתנת לכל הרשת.

הפניית HTTPS לאפליקציה



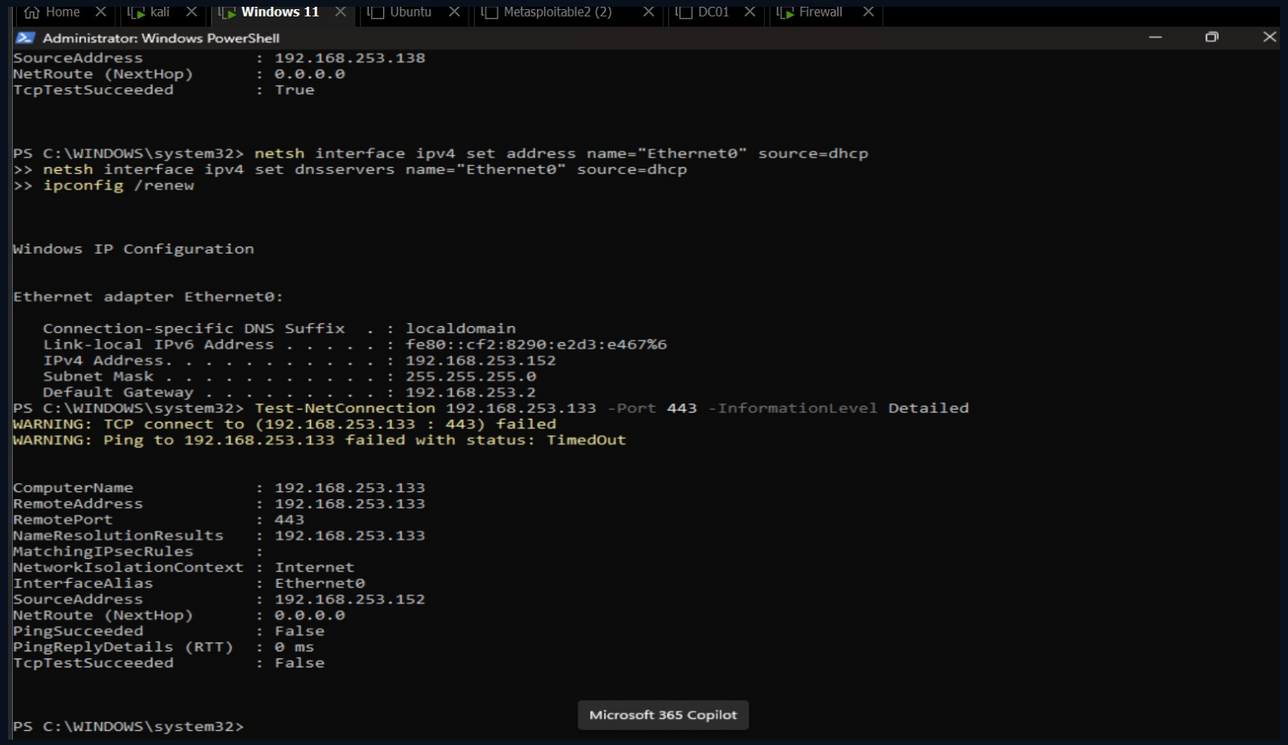
חוק NAT מפנה את פורט 443 ב־WAN אל 192.168.1.195:443. כלל הסינון המשויך מאפשר את התעבורה שהוגדרה.

בדיקה חיובית לפורט 443



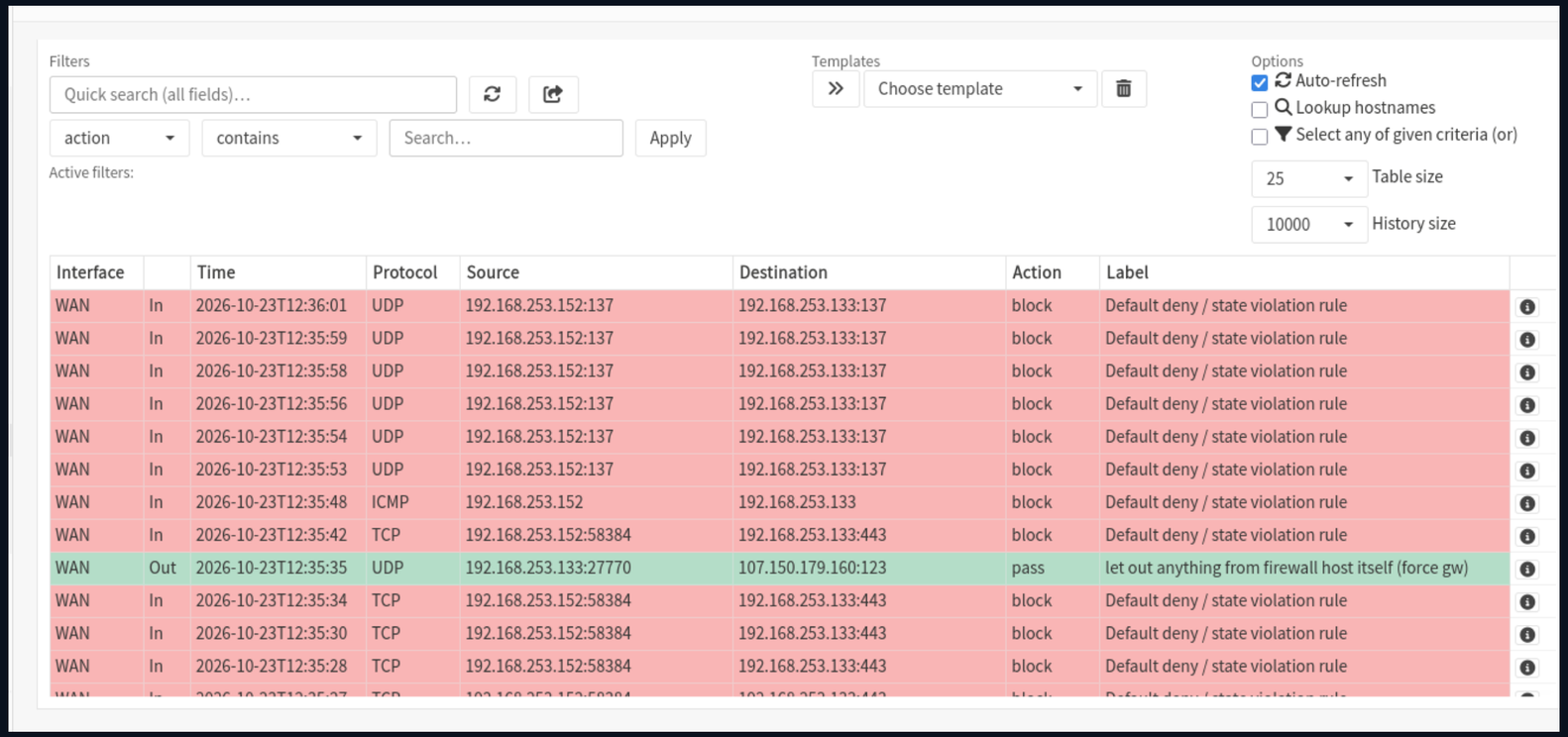
ממחשב הבדיקה המורשה התקבל TcpTestSucceeded: True. זו ראיה לקישוריות TCP ליעד שנבדק.

בדיקה ממקור לא מורשה



החלפתי את כתובת מחשב הבדיקה למקור שלא הותר. ניסיון החיבור לפורט 443 נכשל.

החסימה מופיעה גם בלוג



Interface		Time	Protocol	Source	Destination	Action	Label
WAN	In	2026-10-23T12:36:01	UDP	192.168.253.152:137	192.168.253.133:137	block	Default deny / state violation rule
WAN	In	2026-10-23T12:35:59	UDP	192.168.253.152:137	192.168.253.133:137	block	Default deny / state violation rule
WAN	In	2026-10-23T12:35:58	UDP	192.168.253.152:137	192.168.253.133:137	block	Default deny / state violation rule
WAN	In	2026-10-23T12:35:56	UDP	192.168.253.152:137	192.168.253.133:137	block	Default deny / state violation rule
WAN	In	2026-10-23T12:35:54	UDP	192.168.253.152:137	192.168.253.133:137	block	Default deny / state violation rule
WAN	In	2026-10-23T12:35:53	UDP	192.168.253.152:137	192.168.253.133:137	block	Default deny / state violation rule
WAN	In	2026-10-23T12:35:48	ICMP	192.168.253.152	192.168.253.133	block	Default deny / state violation rule
WAN	In	2026-10-23T12:35:42	TCP	192.168.253.152:58384	192.168.253.133:443	block	Default deny / state violation rule
WAN	Out	2026-10-23T12:35:35	UDP	192.168.253.133:27770	107.150.179.160:123	pass	let out anything from firewall host itself (force gw)
WAN	In	2026-10-23T12:35:34	TCP	192.168.253.152:58384	192.168.253.133:443	block	Default deny / state violation rule
WAN	In	2026-10-23T12:35:30	TCP	192.168.253.152:58384	192.168.253.133:443	block	Default deny / state violation rule
WAN	In	2026-10-23T12:35:28	TCP	192.168.253.152:58384	192.168.253.133:443	block	Default deny / state violation rule

לוג ה־Firewall מציג תעבורה שנחסמה בזמן הבדיקה. השילוב עם כתובת המקור ותוצאת החיבור מחזק את הראיה לאכיפה.

כניסה תקינה כבדיקת בסיס



יצרתי חשבון בדיקה והתחברתי אליו. דף ה־Dashboard נפתח לאחר אימות, ושימש נקודת ייחוס לבדיקות ההמשך.

בדיקת קלט בהרשמה

```
PS C:\WINDOWS\system32> curl.exe -k -i --max-time 15 -H "Origin: https://192.168.253.133" --data-urlencode "username=<script>
alert(1)</script>" --data-urlencode "password=LabOnlyTestValue!2026" "https://192.168.253.133/register"
HTTP/1.1 400 BAD REQUEST
Server: nginx
Date: Fri, 23 Oct 2026 13:15:30 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 1090
Connection: keep-alive
X-RateLimit-Limit: 5
X-RateLimit-Remaining: 4
X-RateLimit-Reset: 1792761391
Retry-After: 60
Content-Security-Policy: default-src 'self'; frame-ancestors 'none'; form-action 'self'
X-Content-Type-Options: nosniff
Cache-Control: no-store

<!doctype html>
<html lang="en">
<head>
    <meta charset="utf-8">
    <title>PT Web Lab - Register</title>
</head>
<body>
    <h1>Create an account</h1>



        <p role="alert">Username: 3-32 English letters, digits or underscores.</p>


    <form method="post" action="/register">
        <p>
            <label for="username">Username</label><br>
            <input id="username" name="username" type="te
                   value="&amp;lt;script&amp;gt;alert(1)&amp;lt;/scri
```

Microsoft 365 Copilot

שלחתי קלט המכיל תגית script לשדה שם המשתמש. היישום החזיר HTTP 400. התוצאה מתייחסת לקלט המסוים שנבדק.

קידוד פלט בתבנית

```
    <p role="alert">Username: 3-32 English letters, digits or underscores.</p>

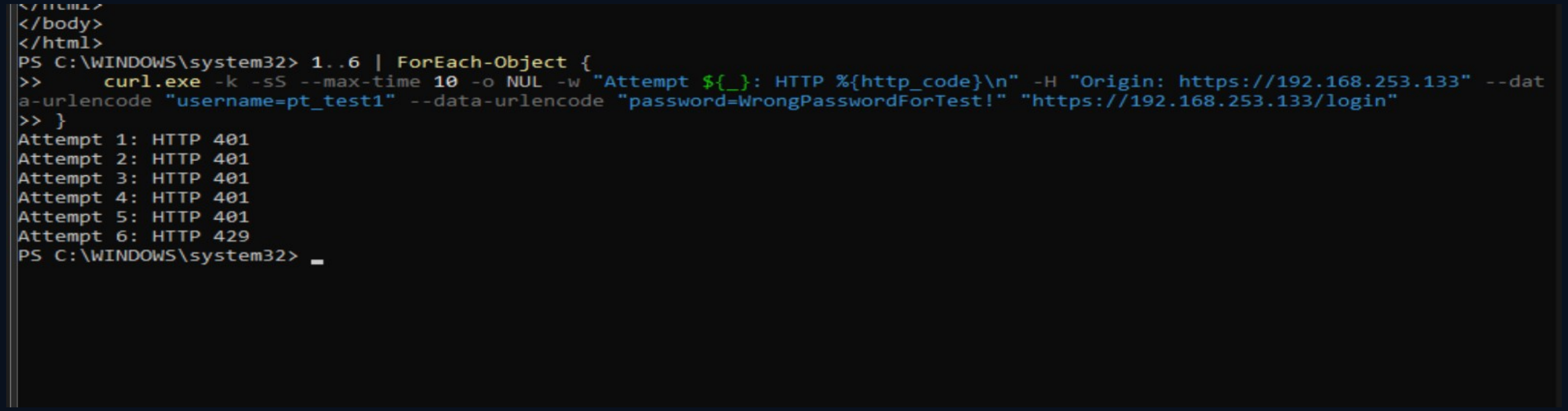

  <form method="post" action="/register">
    <p>
      <label for="username">Username</label><br>
      <input id="username" name="username" type="text"
             value="&lt;script&gt;alert(1)&lt;/script&gt;" required
             minlength="3" maxlength="32"
             pattern="[A-Za-z0-9_]{3,32}"
             autocomplete="username">
    </p>

    <p>
      <label for="password">Password (15-128 characters)</label><br>
      <input id="password" name="password" type="password"
             required minlength="15" maxlength="128"
             autocomplete="new-password">
    </p>

    <button type="submit">Register</button>
  </form>
  </form>
  <p><a href="/login">Already registered? Log in</a></p>
/body>
/html>
/body>
/html>
S C:\WINDOWS\system32> _
```

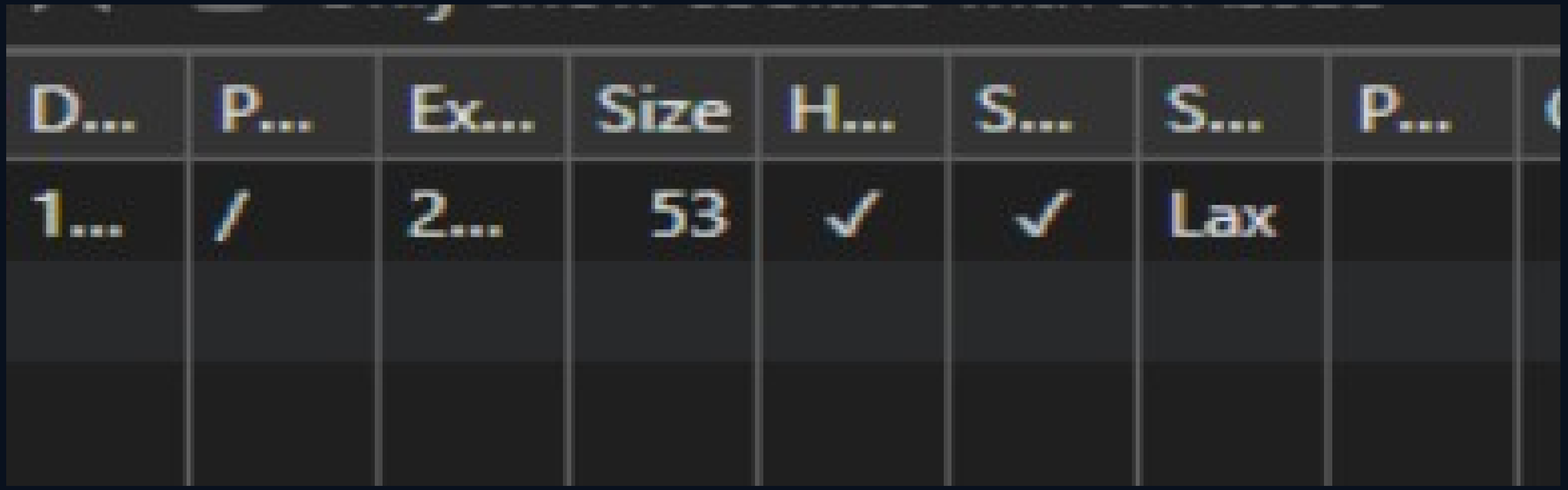
בפלט ה־HTML נראים תווים מקודדים במקום תגית פעילה. בדקתי גם את אופן החזרת הקלט, מעבר לקוד התגובה.

הגבלת ניסיונות כניסה



חמש בקשות כניסה שגויות החזירו 401. הבקשה השישית החזירה 429. ההגבלה במעבדה פועלת לפי IP ובזיכרון התהליך.

הגנות על עוגיית ההתחברות



D...	P...	Ex...	Size	H...	S...	S...	P...
1...	/	2...	53	✓	✓	Lax	

בדקתי את המאפיינים Secure, HttpOnly ו־SameSite=Lax. התמונה מציגה רק את מאפייני העוגייה, ללא ערך ה־Session.

ביטול Session אחרי יציאה

```
>>     curl.exe -k -sS --max-time 10 -o NUL -w "Attempt ${_}: HTTP %{http_code}\n" -H "Origin: https://192.168.253.133" --dat
a-urlencode "username=pt_test1" --data-urlencode "password=WrongPasswordForTest!" "https://192.168.253.133/login"
>> }
Attempt 1: HTTP 401
Attempt 2: HTTP 401
Attempt 3: HTTP 401
Attempt 4: HTTP 401
Attempt 5: HTTP 401
Attempt 6: HTTP 429
PS C:\WINDOWS\system32> $oldSession = [System.Net.NetworkCredential]::new("", (Read-Host "Paste pt_session value" -AsSecureSt
ring)).Password
Paste pt_session value: ****************************************
PS C:\WINDOWS\system32> curl.exe -k -sS --max-time 10 -o NUL -w "HTTP %{http_code} | Redirect: %{redirect_url}\n" -b "pt_sess
ion=$oldSession" "https://192.168.253.133/dashboard"
HTTP 302 | Redirect: https://192.168.253.133/login
PS C:\WINDOWS\system32> $oldSession = [System.Net.NetworkCredential]::new("", (Read-Host "Paste NEW pt_session value" -AsSecu
reString)).Password
Paste NEW pt_session value: ****************************************
PS C:\WINDOWS\system32> curl.exe -k -sS --max-time 10 -o NUL -w "HTTP %{http_code} | Redirect: %{redirect_url}\n" -b "pt_sess
ion=$oldSession" "https://192.168.253.133/dashboard"
HTTP 200 | Redirect:
PS C:\WINDOWS\system32> curl.exe -k -sS --max-time 10 -o NUL -w "HTTP %{http_code} | Redirect: %{redirect_url}\n" -b "pt_sess
ion=$oldSession" "https://192.168.253.133/dashboard"
HTTP 302 | Redirect: https://192.168.253.133/login
PS C:\WINDOWS\system32>
```

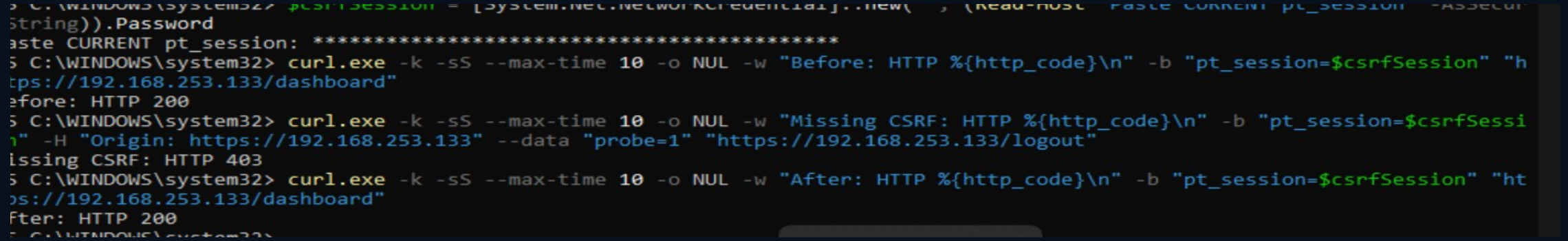
לאחר Logout ניסיתי לגשת שוב ל־Dashboard עם ה־Session הקודם. השרת החזיר 302 לעמוד הכניסה.

בדיקת מקור הבקשה

```
PS C:\WINDOWS\system32> $csrfArgs = @(
>>     "-k", "-sS", "--max-time", "10", "-o", "NUL",
>>     "--data-urlencode", "username=pt_test1",
>>     "--data-urlencode", "password=WrongPasswordForTest!",
>>     "https://192.168.253.133/login"
>> )
>>
>> curl.exe @csrfArgs -H "Origin: https://192.168.253.133" -w "Trusted origin: HTTP %{http_code}\n"
>>
>> curl.exe @csrfArgs -H "Origin: https://csrf-test.invalid" -w "Foreign origin: HTTP %{http_code}\n"
>>
>> curl.exe @csrfArgs -w "Missing origin: HTTP %{http_code}\n"
Trusted origin: HTTP 401
Foreign origin: HTTP 403
Missing origin: HTTP 403
```

מקור HTTPS מורשה הגיע לבדיקת הסיסמה והחזיר 401. מקור זר ובקשה ללא Origin החזירו 403.

יציאה ללא CSRF token נדחית



בקשת Logout ללא token החזירה 403. בדיקה לפני ואחרי הבקשה החזירה 200 ל־Dashboard, כלומר היציאה לא בוצעה.

בדיקות גבול לאורך הסיסמה

```
>>     curl.exe -k -sS --max-time 15 -o NUL `
>>         -H "Origin: https://192.168.253.133" `
>>         --data-urlencode "username=$testUser" `
>>         --data-urlencode "password=$testPass" `
>>         -w "Length ${n}: HTTP %{http_code} | %{redirect_url}\n" `
>>         "https://192.168.253.133/register"
>> }
Length 0: HTTP 400 |
Length 14: HTTP 400 |
Length 15: HTTP 303 | https://192.168.253.133/register?created=1
Length 128: HTTP 303 | https://192.168.253.133/register?created=1
Length 129: HTTP 400 |
PS C:\WINDOWS\system32>
```

בדקתי אורכים 0, 14, 15, 128 ו־129. ההרשמה קיבלה את גבולות המדיניות 15–128 ודחתה ערכים מחוץ לטווח.

כל הסיסמה משתתפת באימות

```
>>     @{ Label = "Short127"; Password = $longPass.Substring(0,127) }
>> )
>>
>> foreach ($check in $checks) {
>>     curl.exe -k -sS --max-time 15 -o NUL `
>>         -H "Origin: https://192.168.253.133" `
>>         --data-urlencode "username=$longUser" `
>>         --data-urlencode "password=$($check.Password)" `
>>         -w "$($check.Label): HTTP %{http_code} | %{redirect_url}\n" `
>>         "https://192.168.253.133/login"
>> }
Full128: HTTP 303 | https://192.168.253.133/dashboard
ChangedLast: HTTP 401 |
Short127: HTTP 401 |
```

סיסמה של 128 תווים התקבלה. שינוי התו האחרון וקיצור ל־127 תווים נדחו, עבור חשבון הבדיקה הזה.

HTTPS ושרת יישום פנימי

```
  GNU nano 9.2          /etc/nginx/sites-enabled/pt-web-lab
server {
    listen 192.168.1.195:443 ssl;
    server_name 192.168.1.195 192.168.253.133;

    ssl_certificate /etc/ssl/certs/pt-web-lab.crt;
    ssl_certificate_key /etc/ssl/private/pt-web-lab.key;
    ssl_protocols TLSv1.2 TLSv1.3;
    server_tokens off;
    client_max_body_size 16k;

    location / {
        proxy_pass http://127.0.0.1:8000;
        proxy_set_header Host $http_host;
        proxy_set_header X-Forwarded-For $remote_addr;
        proxy_set_header X-Forwarded-Proto $scheme;
    }
}
```

Nginx מקבל את חיבור ה־HTTPS ומעביר את הבקשה ל־Gunicorn ב־127.0.0.1:8000. הצילום מתעד את תצורת ה־Reverse proxy.

הקשחת TLS ובדיקה חוזרת



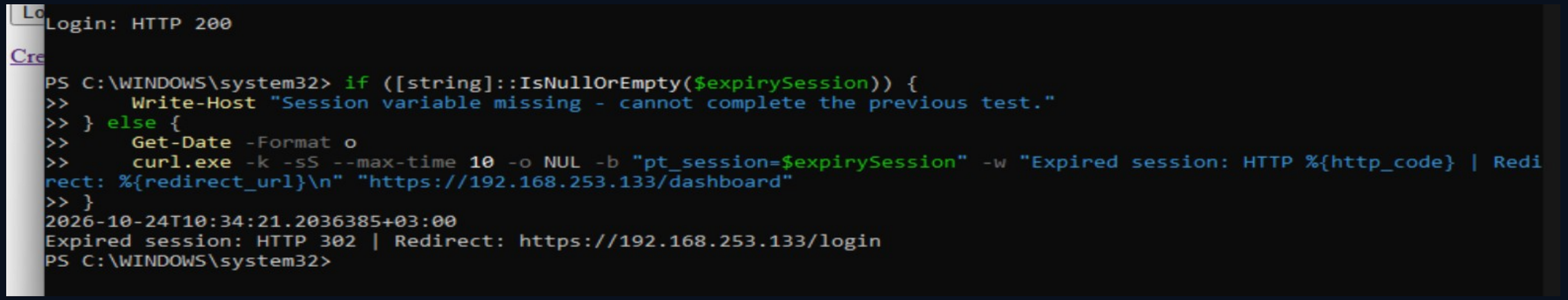
אימתתי תחביר וטענתי את Nginx מחדש. בסריקת Nmap החוזרת נשארו TLS 1.2 עם ECDHE ו־GCM או ChaCha20, וכן TLS 1.3.

בדיקת הפורטים המאזינים

```
┌──(kali㉿kali)-[~]
└─$ sudo ss -lntp
State     Recv-Q    Send-Q        Local Address:Port        Peer Address:Port
Process
LISTEN    0         511           192.168.1.195:443              0.0.0.0:*
 users:(("nginx",pid=138270,fd=5),("nginx",pid=138269,fd=5),("nginx",pid=138268
,fd=5),("nginx",pid=138267,fd=5),("nginx",pid=52217,fd=5))
LISTEN    0         2048             127.0.0.1:8000             0.0.0.0:*
 users:(("python",pid=920,fd=3),("python",pid=889,fd=3))
```

Nginx מאזין בכתובת השרת על 443. שרת היישום מאזין על 8000 ב־Loopback, ללא האזנה ישירה בממשק הרשת.

Session שפג תוקפו נדחה



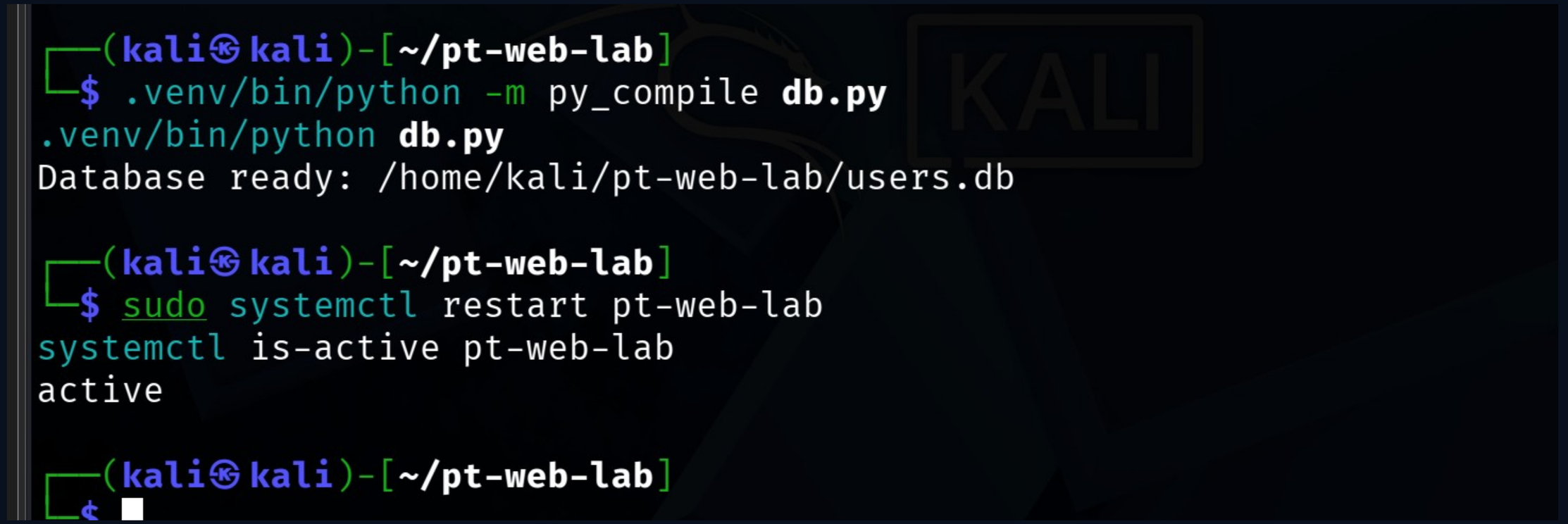
בדיקה חוזרת לאחר כ־52 דקות החזירה 302 לכניסה. הקוד מגדיר תוקף של 30 דקות, אך לא מדדתי את רגע התפוגה המדויק.

בדיקת חשיפה של קבצים רגישים

```
>> TestSucceeded : True
>> $ptPaths = @(
>>     "/login",
>>     "/.env",
>>     "/.git/config",
>>     "/users.db",m32> if ([string]::IsNullOrEmpty($expirySession)) {
>>     "/app.py", "Session variable missing - cannot complete the previous test."
>>     "/auth.py",
>>     "/backup.zip",at o
>>     "/static/users.db"max-time 10 -o NUL -b "pt_session=$expirySession" -w "Expired session: HTTP %{http_code} | Redirect:
>> )edirect_url}\n" "https://192.168.253.133/dashboard"
>> }
>> foreach ($ptPath in $ptPaths) {
>>     curl.exe -k -sS --max-time 10 -o NUL -w "$ptPath -> HTTP %{http_code}\n" "https://192.168.253.133$ptPath"
>> }:\WINDOWS\system32>
2026-10-24T10:35:28.6265712+03:00
/login -> HTTP 200
/.env -> HTTP 404
/.git/config -> HTTP 404
/users.db -> HTTP 404
/app.py -> HTTP 404
/auth.py -> HTTP 404
/backup.zip -> HTTP 404
/static/users.db -> HTTP 404
PS C:\WINDOWS\system32> _
```

נתיבי מסד הנתונים, קובצי Python ונתיבי גיבוי שנבדקו החזירו 404. דף הכניסה החזיר 200 כבדיקת ביקורת.

תיקון אתחול מסד הנתונים



השלמתי יצירה של טבלת sessions באתחול המסד. לאחר התיקון בדקתי תחביר, אתחול ושירות פעיל, ובהמשך כניסה ויציאה.

גיבוי האתר והשירותים

```
    etc/ssl/certs/pt-web-lab.crt \
    etc/ssl/private/pt-web-lab.key \
    -C "$pt_backup_dir" requirements.txt python-version.txt

tar -tzf "$pt_backup_dir/site.tar.gz" > "$pt_backup_dir/contents.txt"

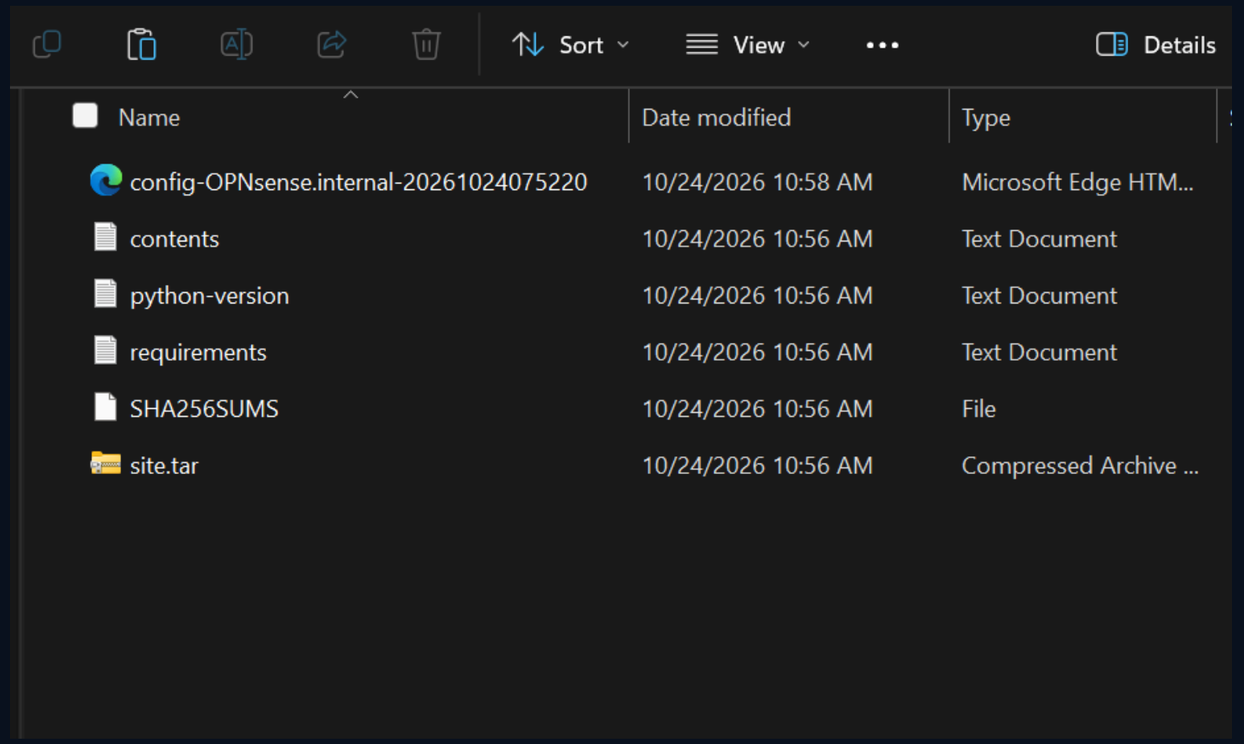
systemctl start pt-web-lab
trap - EXIT

cd "$pt_backup_dir"
sha256sum site.tar.gz > SHA256SUMS
chown -R kali:kali "$pt_backup_dir"

systemctl is-active pt-web-lab
printf 'Backup folder: %s\n' "$pt_backup_dir"
BACKUP
active
Backup folder: /home/kali/pt-backups/site-20261024-035612-DAAYgb
```

יצרתי חבילת גיבוי לאפליקציה, למסד ולהגדרות השירות. לאחר הגיבוי היישום חזר למצב active.

עותק גיבוי במחשב המארח



העברתי חבילה הכוללת ארכיון אתר, הגדרות OPNsense ומידע לשחזור למחשב המארח. תרגיל שחזור מלא עדיין נותר לאימות.



מעבדה שנבנתה ונבדקה

השלמתי את העבודה במסגרת הבדיקות המתועדות.

השלב הבא: תרגיל שחזור מלא מהגיבוי.
הממצאים מתייחסים למעבדה ולבדיקות שבוצעו.